

## DOM based XSS Vulnerabilities

**Title :** DOM based XSS, URL parameter in Popup page

**Description :** This website's popup page processes URL parameters without the proper input sanitisation, it allows malicious scripts to be executed through the parameter query string and this vulnerability occurs because the page directly uses unsanitised URL parameters in the DOM

### Steps to Reproduce :

Step 1 : Navigate to the website <https://cards.buggywebsite.com/>

Step 2 : Click on any cards and then it will take us to the popup.html where we need to copy the URL

Step 3 : After navigating to the popup just add the payload to it

**Payload :** `#?parameter=<img src=x onerror=alert('XSS')>`

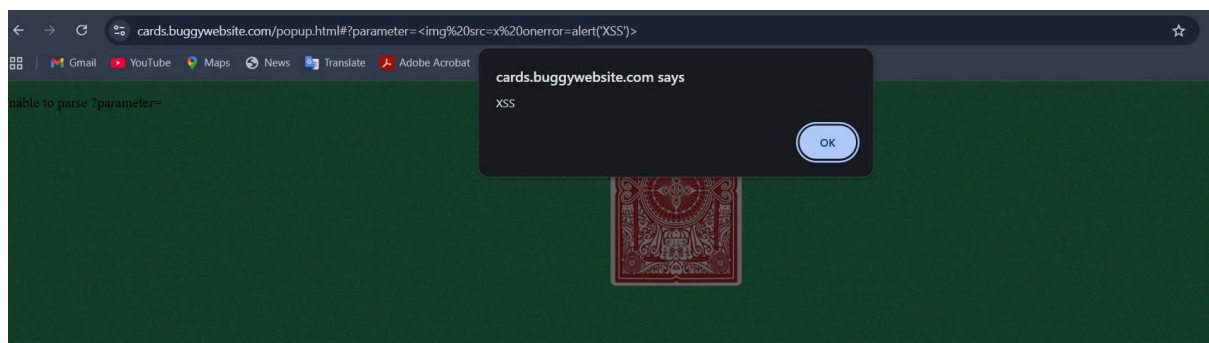
Step 4 : The entire URL looks like this :-

`https://cards.buggywebsite.com/popup.html#?parameter=<img src=x onerror=alert('XSS')>`

Step 5 : Press Enter, the alert box with "XSS" will appear and it will confirm the Vulnerability

**Impact :** Attacker can easily create the malicious URLs that execute arbitrary javascript when visited by users, and potentially leading to session hijacking, credential theft etc.

### Screenshot :



## Title : DOM based XSS in Error Handling of URL parser

**Description :** This website popup page contains a vulnerable URL parameter parser, which uses innerHTML without sanitisation when JSON parsing fails and allowing the XSS attacks through malicious URL parameters.

### Steps to Reproduce :

Step 1 : Navigate to the website <https://cards.buggywebsite.com/>

Step 2 : Click on any cards and the it will take us to the popup.html where we need to copy the URL

Step 3 : Use the payload

**Payload :-** `#?name=test"&indexes=0|0|0`

Step 4 : Click Enter

Step 5 : Right click on the Inspect or press F12, and go to sources there you can check with the code

This parser fails, because of the quote character and the error message will not able to parse which is inserted via innerHTML but if any of the inputs contains scripts they will get executed

**Impact :** Attacker can easily create malicious URLs which are related to the URL parser and execute the code when the URL parsing fails.

### Screenshot :

